Universidad Rafael Landívar
Campus San Alberto Hurtado, S.J. de Quetzaltenango
Curso: Programación Web
Docente: Ing. Manuel Rojas
Título: Eventia: seguridad en aplicaciones web

Nombre: _____ Carné: _____

Fase 1: Investigación y análisis de sitios web
1. Inspección de HTTPS
Seleccionen dos sitios web reales: uno de una institución educativa y otro de un comercio electrónico.
Desde el navegador, realicen las siguientes comprobaciones:

- Identifiquen si utilizan HTTPS.
- Consulten la información del certificado digital desde las herramientas del navegador.
- Identifiquen para qué dominio fue emitido el certificado y su fecha de vencimiento.
- Intenten ingresar utilizando http:// y observen si el navegador o el servidor redirige a HTTPS.
- Abran las herramientas de desarrollador y, desde la pestaña Network, identifiquen el protocolo utilizado en las solicitudes principales.

Como ver certificado digital HTTPS de un sitio web:

- Abran un sitio web, por ejemplo, https://www.google.com.
- Hagan clic en el ícono de controles del sitio, ubicado a la izquierda de la dirección web (en algunas versiones aparece un candado).
- Seleccionen La conexión es segura.
- Busquen la opción El certificado es válido o Información del certificado.
- Se abrirá una ventana donde podrán consultar los detalles del certificado.

Completen la siguiente tabla:

Aspecto	Sitio 1	Sitio 2
Nombre y URL		
¿Utiliza HTTPS?		
¿El certificado es válido?		
Fecha de vencimiento		
¿HTTP redirige a HTTPS?		
¿Encontraron alguna observación?		

2. Investigación de OWASP
Consulten la página oficial de OWASP
Cada grupo debe seleccionar tres riesgos diferentes e investigar:

1. ¿En qué consiste el riesgo?
2. ¿Cómo podría presentarse en Eventia?
3. ¿Qué consecuencias tendría?
4. ¿Qué medida de seguridad permitiría reducirlo?

No deben copiar las definiciones textualmente. Deben relacionarlas con funcionalidades específicas de Eventia.

Fase 2: Auditoría de seguridad de Eventia
Continuarán trabajando con la plataforma desarrollada en la clase anterior.Eventia permite registrar usuarios, publicar eventos, buscar actividades, realizar inscripciones, controlar cupos y consultar las inscripciones realizadas.

Revisen su propia aplicación: Analicen el código y las funcionalidades que ya han desarrollado. Comprueben los siguientes aspectos:

Aspecto de seguridad	Pregunta de revisión
Autenticación	¿Qué mecanismos utilizan para identificar usuarios?
Autorización	¿Un usuario puede modificar eventos que pertenecen a otro organizador?
Validación	¿El backend comprueba los datos recibidos?
Control de cupos	¿Se impide una inscripción que exceda los cupos disponibles?
Contraseñas	¿Cómo se almacenan las contraseñas, si ya implementaron el registro?
Secretos	¿Existen credenciales escritas directamente en el código?
Manejo de errores	¿Se expone información interna de la aplicación?
Dependencias	¿Existen vulnerabilidades conocidas en los paquetes utilizados?

Fase 3: Implementación de controles de seguridad
Apliquen mejoras reales: A partir de su revisión, implementen al menos dos controles de seguridad en Eventia.

Pueden seleccionar entre:

- Validar en el backend que la cantidad de inscripciones sea mayor que cero.
- Impedir inscripciones que superen el cupo disponible.
- Comprobar que únicamente el organizador autorizado pueda modificar su evento.
- Evitar que un usuario consulte inscripciones privadas de otros usuarios.
- Proteger credenciales mediante variables de entorno.
- Mejorar el manejo de errores para no exponer información interna.
- Implementar correctamente el hashing de contraseñas, si ya cuentan con autenticación.

Condición: Las mejoras deben funcionar y deben demostrar mediante una prueba que el sistema rechaza una operación inválida o no autorizada.

Por cada mejora implementada, documenten:

Elemento	Descripción
Problema identificado	¿Qué riesgo encontraron?
Riesgo OWASP relacionado	¿Con qué categoría se relaciona?
Corrección aplicada	¿Qué modificaron?
Prueba realizada	¿Cómo comprobaron que funciona?
Resultado	¿Qué ocurrió después de la corrección?

Entrega: Cada grupo deberá presentar un documento breve con la investigación de los dos sitios web, los dosriesgos OWASP seleccionados, la auditoría de Eventia y las evidencias de las dos mejor as implementadas. También deberán compartir el repositorio actualizado de Eventia, indicando los archivos modificados.